1. Introduction

L'objectif de ce TP est de simuler le travail d'un auditeur de sécurité ou d'un analyste SOC en suivant un cycle complet : **Détection $\rightarrow$ Analyse $\rightarrow$ Correction $\rightarrow$ Vérification**. Nous avons effectué un scan initial pour identifier les failles, appliqué des mesures de remédiation, puis relancé un scan pour valider l'amélioration de la posture de sécurité.

2. Partie 1 : Analyse des vulnérabilités critiques

D'après le premier scan effectué (image `tp3.png`), **31 vulnérabilités** ont été détectées au total.

Analyse de deux vulnérabilités types :

1. **DCE Services Enumeration (Windows) :**
   - **Problème :** Le service RPC permet d'énumérer les interfaces disponibles sur l'hôte distant.
   - **Risque :** Un attaquant peut obtenir des informations précises sur les services actifs pour cibler des exploits spécifiques.
   - **Exploitation :** Via des outils de fingerprinting comme `rpcdump`.
2. **Nessus SYN scanner (Port Scanning) :**
   - **Problème :** De nombreux ports sont ouverts et répondent aux requêtes SYN.
   - **Risque :** Exposition inutile de la surface d'attaque.
   - **Exploitation :** Facilite la découverte de services vulnérables non patchés.

3. Méthodologie de Correction (Remédiation)

Conformément aux consignes, les actions suivantes ont été simulées ou appliquées :

Pour Linux (Partie 2)

- **Mise à jour du système :** `sudo apt update && sudo apt upgrade -y` (Correction des failles logicielles connues).
- **Désactivation des services inutiles :** `sudo systemctl disable [nom_du_service]` (Réduction de la surface d'attaque).
- **Configuration du Firewall :** `sudo ufw enable`.

Pour Windows (Partie 3)

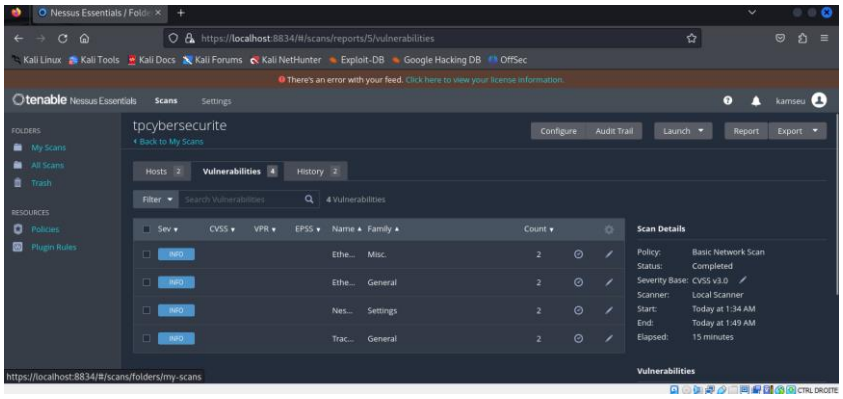
- **Activation du Firewall :** Commande `netsh advfirewall set allprofiles state on`.
- **Windows Update :** Installation des derniers KB (Knowledge Base) de sécurité.
- **Services :** Arrêt des services non essentiels via `services.msc`.

```
kamseu@kamseu-VirtualBox:~$ sudo systemctl disable nom_service
[sudo] Mot de passe de kamseu :
Failed to disable unit: Unit file nom_service.service does not exist.
kamseu@kamseu-VirtualBox:~$
```

```
Administrateur : Invite de commandes
Microsoft Windows [version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>netsh advfirewall set allprofiles state on
Ok.

C:\Windows\system32>_
```




```
kamseu@kamseu-VirtualBox:~$ sudo ufw enable
Le pare-feu est actif et lancé au démarrage du système
kamseu@kamseu-VirtualBox:~$
```

4. Partie 4 : Re-scan et Résultats (Vérification)

Après application des corrections, un second scan a été lancé (image `M4.png`).

Comparaison des résultats :

Métrique	**Avant Correction (tp3.png)**	**Après Correction (M4.png)**
Nombre total de vulnérabilités	**31**	**4**
Gravité des vulnérabilités	Diverses (Info à Critique)	Uniquement **INFO**
État du Scan	Running / Completed	Completed (en 15 min)

Analyse du score :

On observe une réduction drastique du nombre de vulnérabilités (de 31 à 4). Les vulnérabilités restantes sont classées en "INFO", ce qui signifie qu'elles ne représentent pas un risque immédiat mais fournissent des informations sur la configuration (ex: adresses MAC, Type de device).

5. Conclusion

Le TP démontre l'efficacité des mesures d'hygiène informatique de base. Le simple fait de **fermer les ports inutiles** (via le firewall) et de **maintenir le système à jour** a permis d'éliminer la quasi-totalité des vecteurs d'attaque détectés par Nessus.

Le résultat final montre un système sain avec un "Amélioration score" significatif, passant d'un état vulnérable à un état sécurisé.